

Security Risk Notes

MIT ACT — Crennotech Group Project (SiteChat) · Week 4 · 15 August 2026

Risks identified during architecture & Firestore design

Risk	Impact	Mitigation
Misconfigured Firestore security rules expose one company's Site chat to another	High — major data/privacy breach	Rules checked against Site membership on every read/write; peer-reviewed before use
A user impersonates the "system" to post fake system messages	Medium — misleading operational info	Only Cloud Functions (server-side) can write type: system messages; enforced in security rules
Push notification spam if events aren't filtered per user preference	Low — poor user experience	Notification types configurable per user; batching for high-frequency events
Uploaded attachments contain unsafe file types or oversized files	Medium — storage abuse, possible malware	File-type and size checks enforced in Cloud Storage security rules
Deleted/edited messages still visible via cached data on another device	Low — minor confusion	Edited/deleted status flag shown consistently; real Firestore listeners sync state